

Spring AI: Module 11

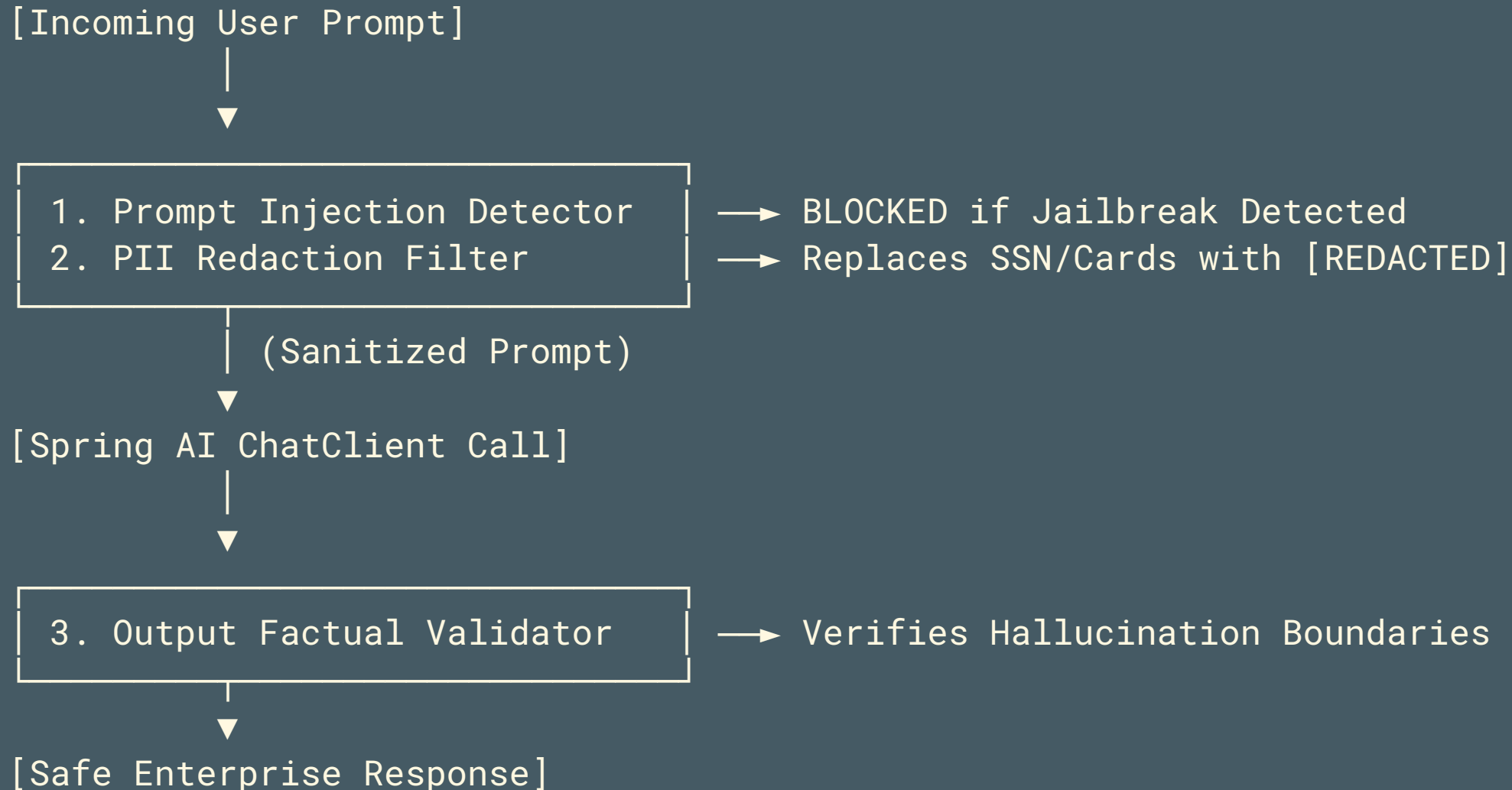
Production Guardrails, Security & Observability

Fortifying Generative AI Workflows in Java

1. The Real-World Risks of Enterprise AI

- LLMs exposed to corporate end-users introduce new threat vectors:
 - **Prompt Injection & Jailbreaking:** Hijacking the model's instructions to leak secrets.
 - **PII Leakage:** Sending customer credit cards or medical data to third-party model providers.
 - **Runaway Costs:** Unmetered token consumption causing massive API billing surprises.

2. Inbound & Outbound Guardrails



3. Observability with Micrometer & OpenTelemetry

- Spring AI integrates natively with Spring Boot Actuator and Micrometer:
 - `spring.ai.requests.total`: Request volume.
 - `spring.ai.security.injections.blocked`: Attack mitigation counter.
 - `spring.ai.inference.duration`: Detailed latency histograms.
- Trace IDs propagate seamlessly to Jaeger/Zipkin.

4. Rate Limiting & Cost Control

- Enforce semantic and token-budget rate limiters:
 - Max 1,000 tokens per employee per hour.
 - Reject duplicate queries using Redis semantic caching.

5. Summary & Best Practices

1. Sanitize all PII before prompt tokens leave your VPC.
2. Intercept adversarial injection patterns before invoking LLMs.
3. Instrument all AI calls with distributed tracing and metric counters.